FACTSAFE

Especificación Funcional y Contexto de Negocio del MVP

Documento interno de referencia para el equipo de desarrollo

Proyecto	FactSafe
Documento	Especificación funcional y contexto de negocio
Versión	1.0
Estado	Base funcional del MVP
Uso	Interno - Equipo de proyecto

Este documento funciona como fuente de verdad funcional del MVP: describe qué debe hacer cada módulo, cómo debe comportarse y cuáles son sus límites.

1. Propósito y uso del documento

Propósito. Formalizar el comportamiento esperado de los módulos de FactSafe para que diseño, frontend, backend, base de datos y pruebas trabajen con el mismo entendimiento funcional y de negocio.

Cómo debe usarse. Antes de desarrollar o modificar una funcionalidad, el equipo debe revisar la sección del módulo correspondiente. Si una historia de usuario o decisión técnica contradice este documento, el alcance debe revisarse y actualizarse antes de implementar.

Nivel de detalle. El documento define el comportamiento funcional. No reemplaza el diseño técnico de APIs, tablas, clases o componentes, pero sí establece qué información debe entrar, cómo debe interpretarse y qué resultado debe producir cada módulo.

2. Contexto del producto

FactSafe es una plataforma web de apoyo para empresas del sector factoring. Su objetivo es ayudar a detectar, clasificar e interpretar posibles amenazas presentes en correos electrónicos y archivos adjuntos, incorporando contexto del negocio para mejorar la priorización de los eventos.

En el MVP, la plataforma no determina de forma autónoma que un correo sea fraude ni ejecuta acciones destructivas. Su función es reunir señales técnicas y de negocio, calcular un nivel de riesgo explicable, estimar un posible impacto financiero y presentar la información para revisión humana.

3. Principios funcionales globales del MVP

- La integración real de correo del MVP será únicamente con Google Workspace / Gmail mediante Gmail API.
- El análisis de amenazas se realizará mediante reglas predefinidas; no se utilizará inteligencia artificial ni machine learning.
- El contexto de factoring utilizado para las correlaciones será información simulada almacenada en la plataforma.
- El sistema podrá detectar señales e inconsistencias, pero no confirmará automáticamente que un correo sea fraudulento.
- El Risk Score debe ser explicable: el usuario debe poder identificar qué factores contribuyeron al resultado.
- Los eventos clasificados como Alto o Crítico deberán generar una alerta por correo electrónico en el MVP.
- FactSafe mostrará recomendaciones o pasos sugeridos, pero no eliminará, bloqueará ni pondrá correos en cuarentena de forma automática.
- Los estados funcionales iniciales de un evento serán: Requiere revisión, En análisis y Cerrado.
- La autenticación se gestionará mediante Amazon Cognito y la persistencia de información mediante SQL Server.

- Toda funcionalidad no descrita expresamente en este documento debe considerarse fuera de alcance hasta ser validada por el equipo.

4. Flujo funcional general

1. El usuario autorizado ingresa a FactSafe.
2. La empresa configura la información básica y carga el contexto factoring simulado necesario para las pruebas.
3. FactSafe se conecta con Gmail y obtiene los correos a procesar.
4. El sistema analiza remitente, dominio, enlaces y archivos adjuntos mediante reglas predefinidas.
5. La información encontrada se compara con el contexto factoring disponible.
6. Se consolidan indicadores técnicos y contextuales.
7. El sistema calcula un Risk Score y asigna un nivel Bajo, Medio, Alto o Crítico.
8. Cuando exista información económica suficiente, se calcula una estimación de impacto financiero potencial.
9. El resultado se registra como un evento de seguridad.
10. El usuario revisa los eventos desde el listado, el detalle y el dashboard.
11. Los eventos Alto o Crítico generan una alerta por correo electrónico.
12. El usuario revisa las recomendaciones y actualiza el estado del evento.

5. Mapa de módulos

Módulo	Responsabilidad principal	Depende de / alimenta a
Autenticación y acceso	Controlar el ingreso a la plataforma.	Cognito / todos los módulos protegidos
Configuración de empresa	Definir parámetros básicos del contexto de la empresa.	Contexto factoring / Risk Score
Data Helper y contexto factoring	Mantener los datos simulados usados para correlación.	Correlación / impacto financiero
Integración con Gmail	Obtener correos y metadatos para análisis.	Análisis de amenazas
Análisis de amenazas	Detectar indicadores técnicos mediante reglas.	Correlación / Risk Score
Correlación con contexto factoring	Contrastar el correo con información del negocio.	Risk Score / impacto financiero
Risk Score	Consolidar señales y priorizar el evento.	Eventos / alertas / dashboard
Impacto financiero	Estimar exposición económica potencial.	Eventos / priorización
Gestión de eventos	Centralizar la revisión y seguimiento.	Alertas / dashboard
Alertas	Notificar eventos Alto o Crítico.	Correo electrónico / eventos
Dashboard	Mostrar una visión resumida de los eventos.	Eventos / Risk Score

6. Módulo de autenticación y acceso

Objetivo	Permitir el acceso únicamente a usuarios autorizados y proteger las funcionalidades de la plataforma.
Contexto de negocio	FactSafe maneja información de seguridad y contexto de negocio, por lo que el acceso debe estar restringido. La autenticación se delega a Amazon Cognito y el backend debe respetar el estado de autenticación antes de entregar recursos protegidos.
Alcance	Incluye inicio de sesión, validación de autenticación, mantenimiento de sesión y control básico de acceso requerido por el MVP.

Funcionamiento esperado

1. El usuario accede a la pantalla de inicio de sesión.

2. Ingresa sus credenciales.

3. Amazon Cognito verifica las credenciales.

4. Si son válidas, se establece la sesión y el usuario puede ingresar a la aplicación.

5. Las solicitudes a funcionalidades protegidas deben realizarse dentro de una sesión válida.

6. Si la sesión no es válida o expira, el sistema debe impedir el acceso y solicitar autenticación nuevamente.

Datos de entrada

- Credenciales del usuario.
- Información de sesión/autenticación proporcionada por Cognito.

Resultados / salidas

- Acceso autorizado o rechazado.
- Sesión válida para consumir funciones protegidas.
- Mensajes de error de autenticación.

Reglas de negocio

ID	Regla de negocio	Comportamiento esperado
AUT-01	Solo usuarios autenticados pueden utilizar módulos protegidos.	Una sesión inválida o ausente debe impedir el acceso.
AUT-02	La autenticación no se gestiona con contraseñas almacenadas en la base de datos de negocio.	La validación de credenciales se delega a Cognito.

ID	Regla de negocio	Comportamiento esperado
AUT-03	Al finalizar o expirar la sesión, el usuario debe autenticarse nuevamente.	No se debe mantener acceso indefinido con una sesión inválida.

Casos especiales y comportamiento esperado

- Credenciales incorrectas: mostrar error sin revelar información técnica interna.
- Sesión expirada: redirigir al inicio de sesión.
- Servicio de autenticación no disponible: informar que no es posible iniciar sesión en ese momento.

Interacción con otros módulos

- Protege el acceso al frontend y a las operaciones expuestas por el backend.
- No participa en el cálculo de riesgo del correo.

Ejemplo funcional

Un usuario intenta ingresar con credenciales válidas. Cognito autentica la cuenta y FactSafe permite el acceso. Si la sesión expira mientras utiliza el sistema, una nueva solicitud protegida debe requerir autenticación nuevamente.

Fuera de alcance del MVP

- Inicio de sesión con redes sociales.
- Recuperación avanzada de cuentas personalizada por FactSafe.
- Flujos empresariales complejos de IAM fuera del alcance del prototipo.

7. Módulo de configuración de empresa

Objetivo	Registrar parámetros generales de la empresa que sirven de contexto para el funcionamiento del MVP.
Contexto de negocio	No todas las empresas factoring manejan el mismo contexto operativo. FactSafe necesita una configuración mínima que permita interpretar correctamente datos de prueba y parametrizar algunos comportamientos del prototipo.
Alcance	Incluye el registro y actualización de información básica de la empresa, como nombre, moneda principal y monto considerado relevante para las pruebas del MVP.

Funcionamiento esperado

1. El usuario accede a Configuración.

2. Completa o modifica los campos habilitados.

3. El sistema valida que los campos obligatorios tengan un formato válido.

4. La configuración se guarda en la base de datos.

5. Los demás módulos consumen estos parámetros cuando corresponda.

Datos de entrada

- Nombre de empresa.
- Moneda principal.
- Monto relevante o umbral definido para el MVP.
- Otros parámetros expresamente aprobados por el equipo.

Resultados / salidas

- Configuración vigente de la empresa.
- Mensajes de validación.
- Parámetros disponibles para otros módulos.

Reglas de negocio

ID	Regla de negocio	Comportamiento esperado
CFG-01	La plataforma debe mantener una configuración vigente por empresa/prototipo.	Las actualizaciones reemplazan los valores vigentes utilizados por los módulos dependientes.
CFG-02	Los campos obligatorios deben validarse antes de guardar.	Los registros incompletos o inválidos no deben persistirse como configuración válida.
CFG-03	Solo se almacenan parámetros que tengan un uso funcional definido en el MVP.	No se agregan campos solo por parecer útiles si ningún módulo los consume.

Casos especiales y comportamiento esperado

- Configuración incompleta: indicar qué campo falta.
- Valor numérico inválido: impedir el guardado y mostrar validación.
- Primera ejecución sin configuración: los módulos dependientes deben manejar la ausencia de contexto de forma explícita.

Interacción con otros módulos

- Provee parámetros a Data Helper, correlación, Risk Score o impacto cuando corresponda.
- No obtiene correos ni analiza amenazas.

Ejemplo funcional

La empresa configura PEN como moneda principal y S/ 50,000 como monto relevante. Estos valores quedan disponibles para las funcionalidades que necesiten interpretar montos durante las pruebas.

Fuera de alcance del MVP

- Configuración contable completa.
- Parametrización administrativa compleja.
- Personalización de reglas por cada cliente fuera de lo acordado para el MVP.

8. Módulo Data Helper y contexto factoring

Objetivo	Mantener la información simulada de negocio necesaria para contextualizar los correos y soportar las pruebas de correlación.
Contexto de negocio	Un correo puede ser técnicamente válido y aun así resultar sospechoso si no coincide con la relación esperada entre cliente, dominio, contacto, deudor, factura o comportamiento habitual de una operación. Para detectar estas diferencias, FactSafe necesita un contexto de negocio previo.
Alcance	Incluye registro/carga de información simulada de clientes, deudores, facturas, montos, monedas, dominios y contactos autorizados, utilizando formularios o archivos Excel/CSV según la funcionalidad implementada.

Funcionamiento esperado

1. El usuario ingresa o carga información de contexto.

2. El sistema valida estructura, tipos de dato y campos obligatorios.

3. Los registros válidos son almacenados.

4. Los registros inválidos se reportan al usuario sin ser tratados como contexto válido.

5. La información aprobada queda disponible para el módulo de correlación y, cuando corresponda, para impacto financiero.

Datos de entrada

- Datos de clientes y deudores simulados.
- RUC u otro identificador utilizado en el prototipo.
- Dominios corporativos autorizados.

- Correos/contactos autorizados.
- Información simulada de facturas y montos.
- Moneda.
- Rangos o montos habituales cuando el escenario de prueba lo requiera.

Resultados / salidas

- Registros de contexto disponibles para consulta.
- Resultado de validación de carga.
- Detalle de registros rechazados cuando corresponda.

Reglas de negocio

ID	Regla de negocio	Comportamiento esperado
CTX-01	El MVP utiliza información simulada, no datos productivos sensibles.	Los escenarios de prueba deben poder ejecutarse sin depender de información real de clientes.
CTX-02	Un registro inválido no debe ser utilizado para correlación.	La validación ocurre antes de considerar el registro como contexto válido.
CTX-03	El dominio/contacto autorizado representa el comportamiento esperado para un cliente.	Una discrepancia podrá convertirse en indicador contextual.
CTX-04	Los rangos habituales se usan como referencia, no como prueba automática de fraude.	Una desviación genera señal para evaluación, no una conclusión definitiva.
CTX-05	Para clientes VIP no se requiere incluir cuenta bancaria como dato obligatorio del archivo de carga.	El contexto mínimo se centra en identidad, contacto, dominio y comportamiento habitual aprobado para el MVP.

Casos especiales y comportamiento esperado

- Archivo con estructura incorrecta: rechazar la carga e indicar el formato esperado.
- Fila con campos faltantes: identificar el registro inválido.
- Cliente sin dominio autorizado: la correlación no debe inventar un dominio esperado.
- Dato contextual ausente: registrar que no fue posible realizar esa comparación.

Interacción con otros módulos

- Alimenta Correlación con contexto factoring.
- Puede alimentar Impacto financiero.
- Recibe parámetros de Configuración cuando sea necesario.

Ejemplo funcional

Se registra el cliente Empresa ABC con dominio autorizado empresaabc.com, contacto pagos@empresaabc.com, moneda PEN y rango habitual de operaciones entre S/ 10,000 y S/ 40,000. Estos valores se utilizarán posteriormente para comparar un correo que aparente pertenecer a ese cliente.

Fuera de alcance del MVP

- Integración con un sistema factoring productivo.
- Sincronización automática con ERP/CRM.
- Uso obligatorio de datos reales.
- Administración maestra completa de clientes.

9. Módulo de integración con Gmail

Objetivo	Obtener los correos electrónicos y metadatos necesarios para que FactSafe pueda procesarlos.
Contexto de negocio	El correo electrónico es el canal de entrada de los eventos que FactSafe analizará. La integración debe limitarse a obtener la información necesaria para el MVP y entregarla al análisis técnico.
Alcance	Incluye conexión con Gmail API, validación del estado de conexión, consulta de mensajes y extracción de datos necesarios para análisis.

Funcionamiento esperado

1. El usuario autoriza o dispone de la conexión configurada con Gmail.

2. El sistema verifica el estado de la conexión.

3. El backend consulta los mensajes mediante Gmail API.

4. Por cada mensaje se extraen metadatos y contenido necesarios para el análisis.

5. Los datos normalizados se entregan al módulo de análisis de amenazas.

6. Los errores de conexión o lectura quedan informados al usuario o registrados para diagnóstico.

Datos de entrada

- Autorización de Gmail.
- Mensajes disponibles en la cuenta conectada.

Resultados / salidas

- Remitente y dirección.

- Dominio del remitente.
- Asunto.
- Fecha/hora.
- Contenido necesario para análisis.
- Enlaces detectables.
- Nombre, tipo y extensión de adjuntos.
- Estado de conexión.

Reglas de negocio

ID	Regla de negocio	Comportamiento esperado
GML-01	La única integración real de correo del MVP es Gmail.	No se implementa Outlook u otros proveedores en esta versión.
GML-02	El módulo obtiene información; no decide el nivel de riesgo.	La evaluación corresponde a módulos posteriores.
GML-03	La integración no debe eliminar ni mover correos automáticamente.	El MVP trabaja en modo de análisis y apoyo a la decisión.
GML-04	Si un dato no está disponible en el mensaje, debe representarse como ausente y no inventarse.	Los módulos posteriores deben poder manejar información incompleta.

Casos especiales y comportamiento esperado

- Gmail no disponible: registrar error de integración.
- Correo sin adjuntos: continuar el análisis con los indicadores disponibles.
- Correo sin enlaces: no generar indicador de enlace por ausencia.
- Mensaje que no puede procesarse: registrar el fallo y evitar que se interprete como análisis exitoso.

Interacción con otros módulos

- Entrega correos al módulo de Análisis de amenazas.
- El resultado final se registra posteriormente como Evento de seguridad.

Ejemplo funcional

FactSafe obtiene un correo de pagos@empresa-abc-pay.com con asunto "Actualización de factura", un enlace y un archivo adjunto. El módulo de Gmail no decide si es peligroso; únicamente entrega esos datos al análisis técnico.

Fuera de alcance del MVP

- Outlook / Office 365.
- Eliminación de mensajes.
- Cuarentena automática.

- Respuesta automática.
- Administración general de buzones.

10. Módulo de análisis de amenazas

Objetivo	Identificar indicadores técnicos relevantes en los correos mediante reglas predefinidas.
Contexto de negocio	Antes de evaluar el contexto de factoring, FactSafe necesita revisar señales observables en el propio correo: remitente, dominio, enlaces y archivos adjuntos. Estas señales son evidencia para la priorización, no una sentencia automática de fraude.
Alcance	Incluye reglas determinísticas sobre remitente/dominio, enlaces y adjuntos. No incluye inteligencia artificial, análisis dinámico de malware ni sandbox.

Funcionamiento esperado

1. Recibe un correo normalizado desde la integración con Gmail.

2. Extrae o utiliza el remitente y su dominio.

3. Evalúa enlaces presentes mediante reglas o patrones definidos.

4. Evalúa adjuntos según nombre, tipo y extensión.

5. Genera indicadores técnicos con resultado y detalle.

6. Entrega los indicadores a Correlación y Risk Score.

Datos de entrada

- Remitente.
- Dominio.
- Enlaces.
- Nombre/tipo/extensión de adjuntos.
- Reglas técnicas predefinidas.

Resultados / salidas

- Indicadores técnicos.
- Coincidencias o señales detectadas.
- Detalle de la regla activada.

Reglas de negocio

ID	Regla de negocio	Comportamiento esperado
ANA-01	Cada indicador debe derivarse de una regla conocida.	El resultado debe poder explicarse al usuario.
ANA-02	La ausencia de un indicador no implica que el correo sea seguro.	Solo significa que esa regla no detectó una señal.
ANA-03	La presencia de una señal no confirma por sí sola un fraude.	El resultado se combina con otros factores en Risk Score.
ANA-04	Las extensiones definidas como riesgosas deben ser parametrizadas o mantenidas en una lista controlada por el proyecto.	La lógica debe ser reproducible en pruebas.

Casos especiales y comportamiento esperado

- Correo sin dominio interpretable: registrar que la validación no fue concluyente.
- Enlace malformado: registrar indicador si cumple la regla definida o marcarlo como no evaluable.
- Adjunto sin extensión reconocible: registrar el dato disponible sin asumir tipo.
- Múltiples indicadores: todos deben conservarse para explicación posterior.

Interacción con otros módulos

- Recibe datos de Gmail.
- Entrega indicadores a Correlación y Risk Score.
- Los indicadores se muestran en el detalle del Evento.

Ejemplo funcional

Un correo incluye un archivo ejecutable o una extensión incluida en la lista de riesgo. El módulo registra el indicador "adjunto con extensión riesgosa". No bloquea el archivo ni concluye automáticamente que sea malware.

Fuera de alcance del MVP

- IA o machine learning.
- Análisis dinámico de archivos.
- Sandbox.
- Antivirus propio.
- Threat Intelligence avanzada en tiempo real.

11. Módulo de correlación con contexto factoring

Objetivo	Relacionar el correo con el contexto de negocio almacenado e identificar coincidencias o inconsistencias relevantes.

Contexto de negocio	El valor diferencial de FactSafe es que una señal técnica puede interpretarse junto con información del proceso de factoring. Un correo que aparenta pertenecer a un cliente puede resultar más relevante si usa un dominio desconocido, un contacto no autorizado o un monto atípico para ese contexto.
Alcance	Incluye comparación entre los datos disponibles del correo y el contexto factoring simulado. La correlación debe producir señales explicables, no decisiones finales.

Funcionamiento esperado

1. Recibe el correo y los indicadores técnicos.

2. Intenta identificar una entidad de contexto relacionada, por ejemplo cliente, deudor, factura u operación simulada.

3. Consulta la información esperada registrada para esa entidad.

4. Compara los valores disponibles del correo con el contexto.

5. Registra coincidencias, inconsistencias y comparaciones no posibles por falta de datos.

6. Entrega los indicadores contextuales al Risk Score y, cuando corresponda, al módulo de Impacto financiero.

Datos de entrada

- Datos del correo.
- Indicadores técnicos.
- Clientes/deudores/facturas simuladas.
- Dominios/contactos autorizados.
- Moneda y montos habituales cuando estén disponibles.

Resultados / salidas

- Coincidencias.
- Inconsistencias contextuales.
- Factores no evaluables por falta de información.
- Datos relacionados para Risk Score e impacto.

Reglas de negocio

ID	Regla de negocio	Comportamiento esperado
COR-01	Una diferencia con el contexto se registra como inconsistencia, no como fraude confirmado.	La interpretación final sigue siendo de apoyo a la revisión humana.
COR-02	No se debe penalizar como discrepancia un dato que no existe en el contexto.	Debe marcarse como no evaluable o sin información suficiente.
COR-03	El dominio/contacto autorizado debe compararse únicamente cuando el cliente relacionado pueda identificarse de manera suficiente.	No se realizan comparaciones arbitrarias entre entidades no relacionadas.
COR-04	Una desviación de monto se calcula contra el comportamiento/rango registrado para el escenario.	La señal resultante se envía a Risk Score.
COR-05	La correlación debe conservar el motivo de cada coincidencia o inconsistencia.	El detalle debe poder mostrarse posteriormente en el evento.

Casos especiales y comportamiento esperado

- No se identifica cliente: registrar que no fue posible correlacionar con un cliente específico.
- Cliente identificado pero sin dominio registrado: no generar inconsistencia de dominio.
- Monto no disponible: no realizar evaluación de monto.
- Múltiples posibles coincidencias: el MVP debe aplicar la regla definida por el equipo o marcar el caso como no concluyente.

Interacción con otros módulos

- Consume Data Helper/contexto factoring.
- Consume información del correo y análisis técnico.
- Alimenta Risk Score e Impacto financiero.
- Sus resultados aparecen en Gestión de eventos.

Ejemplo funcional

El correo afirma pertenecer a Empresa ABC y llega desde empresa-abc-pay.com. En el contexto, Empresa ABC tiene empresaabc.com como dominio autorizado. FactSafe registra una inconsistencia de dominio. Si el correo además hace referencia a S/ 150,000 y el máximo habitual almacenado es S/ 40,000, registra también una desviación de monto. Ninguna señal, por sí sola, confirma fraude.

Fuera de alcance del MVP

- Consulta en tiempo real a un sistema factoring productivo.
- Modificación de operaciones financieras.
- Bloqueo de facturas u operaciones.
- Decisión automática de fraude.

12. Módulo de Risk Score

Objetivo	Consolidar los indicadores disponibles y asignar una prioridad de riesgo explicable al evento.
Contexto de negocio	El equipo necesita una forma consistente de priorizar qué eventos revisar primero. El Risk Score transforma señales técnicas y contextuales en un puntaje y una categoría, manteniendo visibles los factores que lo explican.
Alcance	Incluye reglas y ponderaciones fijas definidas por el proyecto, cálculo de puntaje, clasificación Bajo/Medio/Alto/Crítico y explicación de factores.

Funcionamiento esperado

1. Recibe los indicadores técnicos y contextuales.

2. Identifica las reglas aplicables y sus ponderaciones.

3. Calcula el puntaje acumulado conforme al esquema definido.

4. Convierte el puntaje al nivel de riesgo correspondiente.

5. Conserva la contribución o motivo de los factores considerados.

6. Entrega puntaje, nivel y explicación al módulo de Eventos, Alertas y Dashboard.

Criterios y ponderaciones del Risk Score

Para el MVP se adopta una escala de 0 a 100 puntos. El puntaje es acumulativo y se obtiene sumando únicamente los criterios que resulten aplicables al evento. Esta matriz constituye la versión 1.0 de las ponderaciones funcionales y podrá calibrarse posteriormente con los resultados de las pruebas del prototipo.

Categoría	Criterio	Condición que suma puntaje	Puntos
Identidad del remitente	Remitente / dominio inconsistente	El correo o dominio no coincide con la información autorizada del cliente identificado, o presenta una variación considerada sospechosa por las reglas del MVP.	+25
Enlaces	Enlace sospechoso	Se detecta al menos un enlace cuyo dominio o patrón coincide con las reglas predefinidas de enlaces sospechosos.	+20
Archivos adjuntos	Adjunto riesgoso	El correo contiene al menos un archivo cuya extensión se encuentra dentro de la lista de extensiones de riesgo definida para el MVP.	+20
Contexto factoring	Relación de negocio inconsistente	La relación identificada entre cliente, deudor, factura o contacto contradice información existente en el contexto factoring simulado.	+15
Contexto financiero	Monto fuera del comportamiento habitual	El monto relacionado supera el máximo habitual registrado o el umbral relevante definido para el escenario.	+15
Contexto financiero	Moneda no habitual	La moneda identificada no coincide con la moneda habitual registrada para el cliente u operación relacionada.	+5

Fórmula: Risk Score = suma de los puntos de los criterios aplicables, con un máximo de 100 puntos.

Reglas de aplicación:

• Cada criterio se contabiliza como máximo una vez por evento, aunque existan varias evidencias del mismo tipo.

• Si un criterio no puede evaluarse por falta de información, aporta 0 puntos y debe registrarse como “No evaluable”; la ausencia de datos no debe interpretarse como una inconsistencia.

• Los puntos deben conservar su factor de origen para que el resultado sea explicable en el detalle del evento.

• El puntaje prioriza la revisión y no constituye una confirmación automática de phishing, BEC, fraude o malware.

Categorías de clasificación

Puntaje	Categoría	Interpretación para el MVP
0–24	Bajo	Señales limitadas. El evento se registra y puede revisarse dentro del flujo normal.

Puntaje	Categoría	Interpretación para el MVP
25–49	Medio	Existen señales que justifican revisión, pero no alcanza prioridad alta.
50–74	Alto	Acumulación relevante de señales técnicas o de negocio. El evento debe priorizarse y genera alerta.
75–100	Crítico	Combinación severa de señales. Requiere atención prioritaria y genera alerta inmediata dentro del flujo del MVP.

Los rangos son inclusivos. Por ejemplo, 49 puntos corresponden a Medio y 50 puntos corresponden a Alto.

Datos de entrada

- Indicadores técnicos.
- Indicadores contextuales.
- Reglas de ponderación aprobadas.

Resultados / salidas

- Risk Score.
- Nivel Bajo/Medio/Alto/Crítico.
- Lista de factores que contribuyeron.

Reglas de negocio

ID	Regla de negocio	Comportamiento esperado
RSK-01	El cálculo debe ser determinístico.	Los mismos indicadores y reglas deben producir el mismo resultado.
RSK-02	El resultado debe ser explicable.	El usuario debe poder ver los factores relevantes del puntaje.
RSK-03	La clasificación no equivale a confirmación de fraude.	El nivel sirve para priorizar revisión.
RSK-04	Los umbrales de clasificación son: Bajo 0–24, Medio 25–49, Alto 50–74 y Crítico 75–100.	Los límites deben mantenerse centralizados para evitar criterios distintos entre módulos o pantallas.
RSK-05	Un evento Alto o Crítico activa el flujo de alerta.	Alertas consume la clasificación generada por Risk Score.
RSK-06	La ausencia de información no genera riesgo por sí misma.	Si un criterio no puede evaluarse, aporta 0 puntos y se registra como No evaluable.
RSK-07	Cada criterio aporta como máximo su ponderación definida una vez por evento.	Varias evidencias del mismo tipo pueden mostrarse en el detalle, pero no duplican automáticamente el peso del criterio.

Casos especiales y comportamiento esperado

- Indicadores insuficientes: evaluar únicamente las señales disponibles; los criterios no evaluables aportan 0 puntos y deben quedar identificados como “No evaluable”.
- Regla sin ponderación configurada: no debe incorporarse silenciosamente; debe tratarse como configuración incompleta.
- Puntaje en límite entre categorías: aplicar exactamente los rangos 0–24, 25–49, 50–74 y 75–100.

Interacción con otros módulos

- Consume Análisis y Correlación.
- Alimenta Gestión de eventos, Alertas y Dashboard.
- Puede combinarse visualmente con Impacto financiero, pero ambos módulos mantienen responsabilidades diferentes.

Ejemplo funcional

Ejemplo: un correo presenta un dominio inconsistente (+25), un adjunto riesgoso (+20) y un monto fuera del comportamiento habitual (+15). El Risk Score total es 60 puntos, por lo que el evento se clasifica como Alto. El detalle debe mostrar los tres factores y el aporte de cada uno.

Fuera de alcance del MVP

- IA para predecir riesgo.
- Modelos estadísticos avanzados.
- Aprendizaje automático de ponderaciones.
- Bloqueo automático por puntaje.

13. Módulo de impacto financiero

Objetivo	Estimar la exposición económica potencial asociada a un evento cuando exista información financiera suficiente.
Contexto de negocio	En factoring, dos eventos con señales técnicas similares pueden tener prioridades distintas si uno está relacionado con una operación de mayor importe. La estimación permite aportar contexto financiero a la revisión.
Alcance	Incluye el cálculo de una estimación basada en datos simulados disponibles. La cifra representa exposición potencial y no una pérdida confirmada.

Funcionamiento esperado

1. Recibe la información financiera relacionada identificada durante la correlación.

2. Valida que exista un monto utilizable para la estimación.

3. Aplica la regla de cálculo definida para el MVP.

4. Registra el valor estimado y la información utilizada.

5. Entrega el resultado al detalle del evento y a los componentes de priorización que lo requieran.

Datos de entrada

- Monto de operación/factura simulada.
- Moneda.
- Contexto relacionado disponible.

Resultados / salidas

- Impacto financiero potencial estimado.
- Moneda del resultado.
- Explicación o referencia del dato utilizado.

Reglas de negocio

ID	Regla de negocio	Comportamiento esperado
IMP-01	El impacto es una estimación potencial, no una pérdida confirmada.	La interfaz debe evitar presentarlo como daño real ocurrido.
IMP-02	Sin información financiera suficiente no se debe inventar un monto.	El evento debe indicar que no existe estimación disponible.
IMP-03	La moneda utilizada debe ser consistente con el contexto disponible.	El resultado debe mostrar la moneda asociada.
IMP-04	El cálculo debe poder trazarse al dato de entrada utilizado.	El equipo debe poder explicar de dónde provino la estimación.

Casos especiales y comportamiento esperado

- Monto ausente: mostrar "sin estimación disponible".
- Moneda ausente: no asumir una moneda si el contexto no permite determinarla.
- Más de un monto relacionado: aplicar la regla definida para el escenario o no calcular hasta resolver la asociación.

Interacción con otros módulos

- Consume Correlación y contexto factoring.
- Alimenta Gestión de eventos y puede apoyar la priorización visual.

Ejemplo funcional

Un correo se relaciona con una factura simulada de S/ 120,000. FactSafe utiliza ese valor como referencia para mostrar una exposición potencial asociada al evento, dejando claro que no representa una pérdida confirmada.

Fuera de alcance del MVP

- Predicción de pérdidas futuras.
- Cálculo financiero contable completo.
- Modelos probabilísticos de pérdida.
- Decisiones automáticas basadas en impacto.

14. Módulo de gestión de eventos de seguridad

Objetivo	Centralizar los resultados del procesamiento de correos y permitir su revisión y seguimiento.
Contexto de negocio	El análisis solo es útil si el equipo puede revisar, priorizar y dar seguimiento a lo detectado. Cada correo procesado debe quedar representado como un evento con suficiente contexto para comprender por qué recibió determinada clasificación.
Alcance	Incluye registro de eventos, listado, búsqueda/filtros, detalle, pasos sugeridos y gestión de estados.

Funcionamiento esperado

1. Al finalizar el procesamiento de un correo, el sistema crea o consolida su evento de seguridad.

2. El evento almacena los datos principales del mensaje y los resultados de análisis, correlación, Risk Score e impacto.

3. El usuario consulta el listado y puede buscar o filtrar eventos.

4. Al abrir un evento, visualiza resumen, análisis técnico, contexto factoring, Risk Score, impacto y recomendaciones.

5. El usuario puede actualizar el estado del evento entre los estados permitidos.

6. Los cambios relevantes deben quedar disponibles para trazabilidad.

Datos de entrada

- Datos del correo.
- Indicadores técnicos.
- Correlación.
- Risk Score y nivel.
- Impacto financiero.
- Estado.

Resultados / salidas

- Evento registrado.
- Listado de eventos.
- Detalle del evento.
- Estado actualizado.
- Pasos sugeridos.

Reglas de negocio

ID	Regla de negocio	Comportamiento esperado
EVT-01	Todo correo procesado debe quedar asociado a un resultado de procesamiento.	El sistema no debe perder silenciosamente resultados analizados.
EVT-02	Estados permitidos inicialmente: Requiere revisión, En análisis y Cerrado.	La interfaz debe limitar los estados a los aprobados.
EVT-03	El detalle debe explicar el evento, no solo mostrar un puntaje.	Debe incluir señales técnicas y contextuales relevantes.
EVT-04	Las recomendaciones son pasos sugeridos.	No deben ejecutarse automáticamente sobre Gmail o sistemas financieros.
EVT-05	El usuario debe poder distinguir eventos prioritarios por su clasificación.	Alto y Crítico deben ser visibles de forma clara.

Casos especiales y comportamiento esperado

- Evento con análisis parcial: mostrar qué información sí estuvo disponible y qué no pudo evaluarse.
- Cambio a Cerrado: mantener el registro del evento para consulta posterior.
- Sin impacto financiero: mostrar el resto del detalle normalmente.
- Error durante parte del procesamiento: el sistema debe diferenciar un evento analizado de un procesamiento fallido.

Interacción con otros módulos

- Consolida resultados de todos los módulos de análisis.
- Alimenta Alertas y Dashboard.
- Permite al usuario gestionar la revisión.

Ejemplo funcional

El usuario abre un evento Alto y observa que el dominio no coincide con el cliente, existe un adjunto riesgoso y el monto es atípico. Revisa los pasos sugeridos, inicia la validación con el cliente y cambia el estado de Requiere revisión a En análisis.

Fuera de alcance del MVP

- Eliminación automática del correo.
- Bloqueo automático del remitente.
- Cuarentena automática.
- Recuperación automática ante incidentes.
- Orquestación SOAR.

15. Módulo de alertas

Objetivo	Notificar oportunamente los eventos de mayor prioridad para reducir el tiempo entre detección y revisión.
Contexto de negocio	Los responsables no deberían depender únicamente de revisar el dashboard para conocer un evento crítico. Para el MVP, FactSafe utilizará correo electrónico como canal de alerta.
Alcance	Incluye generación y envío de alertas cuando el nivel sea Alto o Crítico, así como registro del resultado del envío.

Funcionamiento esperado

1. Risk Score clasifica un evento.

2. Si el nivel es Alto o Crítico, se crea una alerta.

3. El sistema construye el mensaje con la información mínima necesaria para identificar el evento.

4. La alerta se envía al destinatario configurado mediante el mecanismo de correo definido.

5. Se registra fecha, destinatario y resultado del envío.

6. Si el envío falla, el evento continúa existiendo y el fallo de alerta debe quedar registrado.

Datos de entrada

- Evento.
- Nivel de riesgo.
- Destinatario configurado.
- Información resumida del evento.

Resultados / salidas

- Alerta enviada o fallida.
- Registro del resultado del envío.
- Referencia al evento.

Reglas de negocio

ID	Regla de negocio	Comportamiento esperado
ALT-01	Solo Alto y Crítico generan alerta automática en el MVP.	Bajo y Medio permanecen disponibles para consulta, sin alerta automática.
ALT-02	Una alerta fallida no debe eliminar ni cambiar el evento.	El evento mantiene su clasificación y estado.
ALT-03	La alerta debe permitir identificar el evento sin exponer más información de la necesaria.	El detalle completo se consulta dentro de FactSafe.
ALT-04	El resultado del envío debe quedar registrado.	Debe distinguirse envío exitoso de fallo.

Casos especiales y comportamiento esperado

- Destinatario no configurado: registrar que no fue posible enviar la alerta.
- Servicio de correo no disponible: registrar fallo y mantener el evento.
- Evento recalculado: evitar duplicados no controlados según la regla que defina el equipo.

Interacción con otros módulos

- Consume Risk Score y Gestión de eventos.
- No modifica el resultado del análisis.

Ejemplo funcional

Un evento obtiene nivel Crítico. FactSafe genera una alerta por correo al responsable con el identificador, asunto, remitente, nivel y acceso/referencia para revisar el detalle dentro de la plataforma.

Fuera de alcance del MVP

- WhatsApp.
- Microsoft Teams.
- SMS.
- SIEM/SOAR.
- Respuesta automatizada ante incidentes.

16. Módulo de dashboard

Objetivo	Presentar una visión resumida del estado de los eventos y facilitar la identificación de los casos prioritarios.
Contexto de negocio	El usuario necesita comprender rápidamente la situación sin revisar evento por evento. El dashboard resume la información ya registrada; no ejecuta análisis independiente.

Alcance	Incluye indicadores básicos del MVP: total de eventos, distribución por nivel de riesgo y visibilidad de eventos recientes y/o Alto/Crítico.

Funcionamiento esperado

1. El usuario ingresa al dashboard.

2. El sistema consulta los eventos registrados y sus clasificaciones.

3. Calcula los indicadores definidos para la vista.

4. Muestra cantidades y distribución por nivel.

5. Muestra eventos recientes o prioritarios según el diseño aprobado.

6. Al ingresar a un evento desde el dashboard, el usuario accede al detalle correspondiente.

Datos de entrada

- Eventos registrados.
- Niveles de riesgo.
- Fechas.
- Estados.

Resultados / salidas

- Total de eventos.
- Distribución Bajo/Medio/Alto/Crítico.
- Eventos recientes.
- Eventos Alto/Crítico destacados.

Reglas de negocio

ID	Regla de negocio	Comportamiento esperado
DSH-01	El dashboard refleja información existente en Eventos.	No debe mantener una fuente de verdad independiente.
DSH-02	Los indicadores deben actualizarse conforme se registran o cambian los eventos.	La vista debe ser coherente con el listado.
DSH-03	Alto y Crítico deben ser fáciles de identificar.	La priorización visual debe corresponder al nivel calculado.
DSH-04	El dashboard no recalcula el Risk Score.	Solo presenta resultados ya generados.

Casos especiales y comportamiento esperado

- Sin eventos: mostrar estado vacío comprensible, no un error.
- Eventos sin impacto financiero: no impedir los indicadores de riesgo.
- Diferencia entre listado y dashboard: debe tratarse como inconsistencia a corregir, pues ambos consumen la misma fuente funcional.

Interacción con otros módulos

- Consume Gestión de eventos y Risk Score.
- Permite navegar al detalle del evento.

Ejemplo funcional

El dashboard muestra 24 eventos: 10 Bajo, 7 Medio, 5 Alto y 2 Crítico. Los eventos Alto y Crítico aparecen destacados para facilitar su revisión inmediata.

Fuera de alcance del MVP

- Analítica avanzada.
- Predicciones.
- BI externo.
- Métricas no vinculadas al alcance funcional del MVP.

17. Escenario integral de referencia

Este escenario sirve como contexto común para comprender cómo colaboran los módulos:

1. En el contexto simulado existe el cliente Empresa ABC con dominio autorizado empresaabc.com y un rango habitual de operaciones de hasta S/ 40,000.

2. Gmail recibe un correo desde pagos@empresa-abc-pay.com con un adjunto y una referencia a una operación por S/ 150,000.

3. Integración con Gmail obtiene el correo y entrega sus datos al análisis.

4. Análisis de amenazas detecta los indicadores técnicos disponibles, por ejemplo un adjunto con extensión incluida en la lista de riesgo.

5. Correlación identifica que el dominio no coincide con el dominio autorizado y que el monto se encuentra fuera del comportamiento habitual registrado.

6. Risk Score combina los indicadores conforme a las ponderaciones definidas y clasifica el evento, por ejemplo como Alto.

7. Impacto financiero utiliza el monto relacionado para mostrar una exposición potencial, sin afirmar que sea una pérdida confirmada.

8. Gestión de eventos registra el resultado y muestra el detalle con los factores detectados y los pasos sugeridos.

9. Alertas envía un correo al responsable porque la clasificación es Alto.

10. Dashboard actualiza los indicadores y muestra el evento entre los casos prioritarios.

> *Importante: en este escenario FactSafe no concluye automáticamente que el correo es fraude. El sistema proporciona evidencia, contexto y prioridad para apoyar la revisión humana.*

18. Reglas de cambio de alcance

- Una nueva funcionalidad que modifique el comportamiento descrito debe documentarse antes de implementarse.
- Si una HU requiere datos que todavía no existen en este documento, el equipo debe validar si realmente pertenecen al MVP.
- Las reglas de negocio no deben quedar implícitas solo en código; las decisiones relevantes deben reflejarse en esta especificación.
- Cambios en categorías de riesgo, ponderaciones, estados o canales de alerta deben considerarse cambios funcionales y actualizarse aquí.
- Integraciones adicionales (por ejemplo Outlook, Teams, WhatsApp o un sistema factoring real) requieren una ampliación explícita del alcance.

19. Checklist para implementar una funcionalidad

- ¿Se entiende qué problema de negocio resuelve?
- ¿Están definidos los datos de entrada?
- ¿Están claras las reglas de negocio aplicables?
- ¿Está definido qué ocurre cuando faltan datos o hay errores?
- ¿Está definido el resultado que debe persistirse o mostrarse?
- ¿Está claro qué módulo consume el resultado?
- ¿La funcionalidad permanece dentro del alcance del MVP?
- ¿Los casos de prueba pueden derivarse del comportamiento documentado?